# activemq / security tool responses

activemq 5.17.3 decoded an attacker-chosen class through openwire. the spring context class loaded the xml payload, which started shell commands. this case includes command execution and attack-linked document-transfer records, so it can show where detection, data blocking and containment each took effect. the documents were synthetic and the receiver stayed inside the isolated lab.

**configuration 1:** haproxy 2.9 openwire tcp gateway, et-open ips through inline nfqueue, lab drop rule 1003001, egress dlp block mode and an external-receiver:8080 destination allowlist. docker isolation and wazuh telemetry were present. no http waf was on the openwire path.

**configuration 2:** the same controls, with the broker removed from the protected internal network and an added java child-process monitor feeding wazuh rule 110151.

activemq

```
rce-status.txt: "confirmed"
broker-process-identity.txt: "uid=0(root) gid=0(root) groups=0(root)"
```

## case summary

| stage | configuration 1 | configuration 2 | meaning |
|---|---|---|---|
| command execution | confirmed | confirmed | the added controls did not remove rce |
| exploit signature | 2049045 / allowed | 2049045 / allowed | both attempts were visible to ips |
| recognized broker document | 221 bytes / 403 | no document retrieved | different stopping points |
| unrecognized broker document | 201 / 186-byte receipt | no egress attempt; no data | segmentation limited the later chain |
| runtime alarm | no monitor events in this stream | 110151 / level 12 | process behavior became visible |

# ips and siem / detected, allowed

wazuh

```
timestamp: "2026-10-10T13:30:42.257+0000"
rule.id: "86601"
rule.level: 3
rule.description:
   "Suricata: Alert - ET EXPLOIT Apache ActiveMQ Remote Code Execution Attempt
   (CVE-2023-46604)"
data.timestamp: "2026-10-10T13:30:41.844941+0000"
data.alert.signature_id: "2049045"
data.alert.severity: "1"
data.alert.action: "allowed"
```

et sid 2049045 identified the openwire rce attempt, but the recorded action was allowed. wazuh rule 86601 received the alert at level 3 even though the suricata event carried severity 1. that is the generic siem rule's level, not an enforced prevention action.

wazuh

```
timestamp: "2026-10-10T13:30:42.257+0000"
rule.id: "86601"
rule.level: 3
rule.description: "Suricata: Alert - SCL OpenWire independent positive control"
data.timestamp: "2026-10-10T13:30:41.296684+0000"
data.alert.signature_id: "1003001"
data.alert.signature: "SCL OpenWire independent positive control"
data.alert.action: "blocked"
```

| signature | what it identified | recorded action |
|---|---|---|
| 1003001 | deliberate openwire positive-control probe | blocked |
| 2049045 | activemq rce attempt | allowed |
| 2049008 and 2049009 | vulnerable-instance information in the connection | allowed |

the drop control worked immediately before the exploit. inline placement alone did not turn the et alert into a drop. the instance-information signatures add exposure context; they are not themselves proof that a command ran.

# configuration 1 / data movement

wazuh

```
timestamp: "2026-10-10T13:30:42.275+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "active-mq-rce-egress-recognized"
data.verdict: "block"
data.reason: "request_content"
data.match_types: ["confidential_label", "synthetic_api_key", "tracked_document"]
data.bytes: "221"
```

the recognized 221-byte document matched confidential-label, synthetic-api-key and tracked-document checks. the egress gateway blocked it with 403. rule 110101 recorded that content-policy block.

wazuh

```
timestamp: "2026-10-10T13:30:42.295+0000"
rule.id: "110120"
rule.level: 10
rule.description: "SCL isolated receiver recorded data movement"
data.request_id: "active-mq-rce-egress-unrecognized"
data.bytes: "186"
data.sha256: "e14d6e40d9d55c6293957eb04fdf5cff846ac41f7d9b280d579d16cc2ff2419c"
```

| broker document | gateway decision | receiver proof | why |
|---|---|---|---|
| recognized / 221 bytes | 403 / blocked | no matching receipt | known content markers matched |
| unrecognized / 186 bytes | 201 / allowed | matching request id and sha256 | destination allowed; no blocking content match |

this receipt is linked to the rce payload by its request id, not just to a generic egress test. the archive contains repeated attempts, so the selected 186-byte receipt is not presented as a total byte count for the whole run. the transfer was visible to the receiver and siem even though content policy allowed it.

# configuration 2 / containment

wazuh

```
timestamp: "2026-10-16T01:14:18.351+0000"
rule.id: "110151"
rule.level: 12
rule.description: "SCL Java service spawned an unexpected utility process"
data.timestamp: "2026-10-16T01:14:17.513932+00:00"
data.component: "runtime-monitor"
data.event_type: "unexpected_child_process"
data.pid: "257"
data.parent_pid: "43"
data.command: "sh"
```

lab rule 110151 fired because the runtime monitor reported an unexpected utility process from the java service. the stream records sh and curl processes. this level-12 alarm was raised after execution started; the monitor did not prevent the shell from running.

activemq

```
recognized.bytes: "0"
recognized.egress_status: "NOT_ATTEMPTED_NO_DATA"
recognized.receiver_record: "no"
unrecognized.bytes: "0"
unrecognized.egress_status: "NOT_ATTEMPTED_NO_DATA"
unrecognized.receiver_record: "no"
```

the rendered compose snapshot removes protected_internal from the broker's network memberships. the saved recognized and unrecognized document files are absent, and both egress statuses are not attempted because no data was obtained. that supports containment of this document-retrieval step, alongside the still-confirmed rce.

| control | observed response | correct credit |
|---|---|---|
| network segmentation | broker lost the protected internal network; no documents retrieved | limited the later data-access step |
| runtime monitor / 110151 | unexpected sh and curl activity reported | detected behavior after execution |
| egress dlp | no attack-linked data submission in this run | cannot be credited with blocking absent payloads |

# what dlp recognized

these are separate synthetic classifier probes. they do not establish that this cve stole those test documents. their request ids identify the control traffic.

wazuh

```
timestamp: "2026-10-16T01:14:26.352+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "CVE-2023-46604-mode-b-20261016T011303Z-recognized_confidential"
data.verdict: "block"
data.reason: "request_content"
data.match_types: ["confidential_label", "synthetic_api_key", "tracked_document"]
data.bytes: "65"
```

lab rule 110101 reported the gateway's block. the reason was request content, so this was a classifier decision. the gateway enforced it; wazuh recorded it.

wazuh

```
timestamp: "2026-10-16T01:14:26.364+0000"
rule.id: "110120"
rule.level: 10
rule.description: "SCL isolated receiver recorded data movement"
data.request_id: "CVE-2023-46604-mode-b-20261016T011303Z-unrecognized_restricted"
data.component: "external-receiver"
data.bytes: "79"
```

| sample | payload bytes | gateway | receiver |
|---|---|---|---|
| public control | 25 | 201 / allowed | recorded |
| recognized confidential | 65 | 403 / blocked | no receipt |
| unrecognized restricted | 79 | 201 / allowed | recorded |
| base64 of recognized sample | 56 | 201 / allowed | recorded |

rule 110120 records receipt of data. it also fires for the public control, so its name alone does not prove theft. the unrecognized and base64 samples expose gaps in this classifier policy.

# findings and fixes

| layer or rule | visibility in these runs | prevention or containment |
|---|---|---|
| haproxy tcp gateway | forwarded openwire traffic | did not repair the vulnerable decoder |
| http waf | not on this tcp messaging path | no waf block should be claimed |
| 2049045 / 86601 | exploit identified and received by siem | allowed; rce still occurred |
| 1003001 | positive-control probe identified | probe dropped; not proof all signatures drop |
| 110101 and 110120 | recognized block and unrecognized receipt recorded | dlp stopped one class, allowed the other |
| 110151 | unexpected child processes identified | alarm only; no execution prevention shown |
| segmentation | broker no longer attached to protected internal network | document access failed after rce |

**patch the decoder.** upgrade brokers and java openwire clients to a maintained, fully patched release. restrict messaging access and unnecessary broker egress. run the service as a dedicated non-root user and constrain child-process execution where normal operation allows it.

**check enforcement separately from alerting.** validate the intended et rule action on a controlled replay, retain runtime telemetry, and test both recognized and unrecognized documents. keep segmentation even after patching: this run shows how it can limit damage when execution is already possible.

## references

apache technical guidance - openwire class loading and broker/client updates

emerging threats announcement - 2049045 is an rce-attempt signature

suricata rule actions - alert, drop and reject have distinct effects

wazuh suricata rules - 86601 reports alert events at its configured level